équivalent... C'est du moins la meilleur façon que je trouve de la définir...

• La première étape consiste à identifier la référence directe à un objet qui peut être de plusieurs façon l'une d'elle étant le paramètre d'URL ou API. Exemple ?uid=1 ou encore ?filename=file_1.pdf. On pourra alors fuzzer ou tester de manière incrémental pour voir à quel paramètre la requête nous renverrai des données auxquelles nous ne devrions pas avoir accès.

• Encore une des nombreuse façon pourrait être les requêtes AJAX ;(echange données en arrière plan entre le navigateur et le serveur sans recharger complètement la page) qui peuvent intégrer des références directes à un objet non-sécurisé

Notons que certaines références à un objet peuvent être fuzzées de manière encodées ou hashées. Et une bonne méthodologie pour la recherche d'IDOR est de créer plusieurs comptes et de comparer et tester les références aux objets.

• Une idor ne se limite évidemment pas à de la lecture de fichier elle peut nous permettre d'accéder à des fonctionnalités administrateur, des api auquel ne devrais pas avoir accès et bien d'autres.

Et une dernière ligne pour conclure toujours chercher et maitriser le fonctionnement du control d'accès à l'object visé avant d'en chercher une potentielle faille, c'est logique!

XML - Injection d'Entité Externes (XXE)

Les vulnérabilités arrivent lorsque des données sont extraite d'une entrée utilisateur sans être correctement assainis permettant ainsi d'utiliser des fonctionnalités XML pour effectuer des actions malveillantes

• Composant Clés:

XML (Extensible Markup Language): Un langage similaire à html mais utilisé pour stocker et transporter des données de manière sécurisé

DTD (Document Type Definition): Définit la structure légale et les éléments d'un document XML. Une DTD peut être interne au document ou externe (chargée depuis un fichier ou une URL)

Entité (Entity): Une sorte de variable définie dans la DTD. Elle est déclarée une fois et peut être réutilisée plusieurs fois dans le document.

Le danger vient des entités externes. Une entité peut être définie pour charger son contenu depuis une source externe en utilisant le mot-clé SYSTEM.
Même si au premier abord un site web récupère les données au format JSON il pourrait accepter le XML si on fais une conversion correct et qu'on change le content-type, et ainsi être potentiellement vulnérable aux XXE.

Comme on l'a vu le coeur de l'attaque consiste à définir une entité externe avec le mot clé SYSTEM pour qu'elle pointe vers une ressource locale, pour les fichiers contenant des caractères spéciaux leurs lectures peut échouer pour les applications PHP il y a cependant des wrappers permettant l'encodage en base64, (et très rarement l'exécution de code à distance via le wrapper expect -> (très rare car pas par default)
Et même un DOS via des entités avec des auto-referencement en boucles:

1- Lecture de fichier Simple:
<!DOCTYPE email [<!ENTITY xxe SYSTEM "file:///etc/passwd">]>
Puis referencement dans le champ vulnerable. Ex: <email>&xxe;</email>